

Incident Reconstruction & Findings Report

Greenfield Logistics — Hands-on-Keyboard Intrusion & Domain Compromise

Field	Detail
Case ID	GF-INC-2026-0704
Severity	P1 — Critical (full Active Directory domain compromise, data exfiltration confirmed)
Incident date	4 July 2026, 10:00 UTC – 5 July 2026, 03:00 UTC
Hosts in scope	GF-WS01 (10.1.0.133), GF-SRV01 (10.1.0.169), GF-DC01 (10.1.0.150)
Domain	greenfield.local
Prepared for	Sarah Chen — Security Lead, Greenfield Logistics
Telemetry sources	Microsoft Sentinel — LAW-SilentCorridor (ASIM) & LAW-Cyber-Range (Defender XDR / MDE)
Status	Contained on GF-WS01 by Defender attack disruption; SRV01 & DC01 require rebuild

All findings below are cited to the specific telemetry table and timestamp (UTC) from which they were derived.

1. Executive Summary

On 4 July 2026, a financially-motivated intruder achieved initial access to **GF-WS01** by weaponising Greenfield's internal AI web-page-summariser. The tool — a scheduled `python.exe` process that fetches and summarises external pages — retrieved an attacker-controlled page and was command-injected into spawning an AMSI-bypassing PowerShell loader. That loader pulled and injected an **AdaptixC2** implant, giving the actor a hands-on-keyboard foothold at approximately 10:15 UTC.

From that foothold the actor conducted local reconnaissance, established three independent persistence mechanisms, harvested and reused the privileged **svc_backup** service account, and moved laterally to the file/SQL server **GF-SRV01** and then to the domain controller **GF-DC01**. On the DC they dumped credentials (LSA secrets / SAM / NTDS), reset a domain user's password, operated under additional domain accounts, and forged a **Kerberos Golden Ticket** — compromising the `krbtgt` account and, with it, the entire `greenfield.local` domain.

Finance data from GF-SRV01 shares and domain data from the DC were staged, compressed to `exfil.zip`, and exfiltrated via PowerShell to an attacker-controlled Azure Blob endpoint (`sanclogicart14191.blob.core.windows.net`) between 19:34 and 19:46 UTC. Microsoft Defender automatically disrupted GF-WS01, but the intrusion had already reached full domain compromise. **This must be treated as a domain-wide breach: assume every credential in greenfield.local is compromised.**

Top-line facts

- **Initial access vector:** indirect prompt-injection / command-injection of the AI page-summariser (`python.exe`) on GF-WS01.
- **Depth:** full Active Directory domain compromise (Golden Ticket / `krbtgt`) — the deepest possible outcome.
- **Credentials compromised:** `sancadmin`, `svc_backup`, `t.harris` (password reset), `d.williams`, and `krbtgt` → effectively the entire domain.
- **Data impact:** Finance shares and domain data staged, archived and exfiltrated to attacker Azure Blob storage.

- **Additional exposure:** attacker discovered two further hosts not originally in scope — GF-BKP01 (backup) and GF-WEB01.

2. Environment & Host Map

Three hosts were declared in scope. Internal IPs were derived from each host's own outbound network telemetry (WindowsNetwork_CL). A fourth address, 10.1.0.120, was confirmed NOT to be a Greenfield asset — it never appears as its own device and acted only as an attacker source, RDP'ing (Type-10) into both GF-WS01 and GF-SRV01 and authenticating svc_backup to the DC. It is assessed as the attacker's operator / jump host on the subnet.

Host	Internal IP	Role	Compromise status
GF-WS01	10.1.0.133	Workstation (runs AI page-summariser)	Patient zero / foothold. Contained by Defender attack disruption.
GF-SRV01	10.1.0.169	File & Microsoft SQL server (Finance shares)	Compromised — AdaptixC2, AnyDesk RAT, data staging. Rebuild.
GF-DC01	10.1.0.150	Active Directory Domain Controller	Fully compromised — credential dump + Golden Ticket. Rebuild + domain recovery.
10.1.0.120	—	ATTACKER operator / jump host (not a Greenfield asset)	Hostile infrastructure — block & investigate origin.
GF-BKP01 / GF-WEB01	(discovered)	Backup server / web host	Targeted for discovery (port scans). Investigate for compromise.

3. Attack Timeline (UTC)

Consolidated chronology of confirmed adversary actions. Benign operational churn (fresh-profile logon noise, Azure guest-agent Run Command, Splunk/Defender agents, and the summariser's ordinary hourly fetches) has been excluded.

Time	Host	Action	Credential
~10:15	GF-WS01	AI summariser (python.exe) command-injected → AMSI-bypass PowerShell → AdaptixC2 loader from cdn.cloud-endpoint.net	(page-summariser ctx)
10:15–10:16	GF-WS01	python.exe / powershell.exe beacon to cdn.cloud-endpoint.net (172.67.174.46)	—
~10:20+	GF-WS01	Local recon: whoami, net user/localgroup, net view, arp, ipconfig, cmdkey /list, PSReadLine history read	sancadmin
~10:20+	GF-WS01	certutil URLCache download of svchost_upd.exe; XOR(0x4A) shellcode injection via Add-Type	GREENFIELD\sancadmin
11:49	GF-WS01	Persistence: scheduled task 'MicrosoftHealthUpdate' + Run key 'WindowsHealthService'	GF-WS01\sancadmin
—	GF-WS01	Persistence: service hijack — GFUpdaterSvc binary replaced with payload	sancadmin
—	GF-WS01	Defender tamper (FeatureDisable) + AMSI tampering	GF-WS01\$
11:29–12:00	GF-WS01→SRV01	svc_backup password reuse/spray (VeeamBackup2026!, BackupAdmin2025!, Greenfield2024)	svc_backup
12:00:19	GF-SRV01	svc_backup Type-3 logon SUCCEEDS from 10.1.0.133	svc_backup
10:46 / 13:06 / 14:21	GF-SRV01	AnyDesk RAT executed / installed as service	SRV01\$, t.harris
~13:1x	GF-SRV01	Domain password of t.harris RESET to 'Summer2025' (net user ... /domain)	GF-SRV01\$
12:53 / 15:54 / 18:54	GF-SRV01	Robocopy recursive staging of Finance data	GF-SRV01\$

Time	Host	Action	Credential
~15:1x	GF-DC01	Impacket remote-service execution (RemoteExec); AD enumeration; repadmin	t.harris / d.williams
15:14	GF-DC01	PowerShell Compress-Archive → C:\Windows\Temp\exfil.zip	GF-DC01\$
~15:xx	GF-DC01	Credential theft: LSA secrets / SAM / NTDS dump	(privileged)
15:47	GF-DC01	svc_backup Type-3 logon SUCCEEDS from operator 10.1.0.120	svc_backup
~15:xx+	GF-DC01	Golden Ticket forged (krbtgt) — full domain compromise	krbtgt (forged)
19:34–19:46	GF-WS01	exfil.zip uploaded via PowerShell to sanclogicart14191.blob.core.windows.net	—
ongoing	GF-WS01	Defender attack disruption isolates host	—

4. Kill-Chain Reconstruction

4.1 Initial Access — weaponised AI page-summariser (GF-WS01)

The earliest malicious execution on GF-WS01 was a PowerShell process whose parent was **python.exe** — the scheduled AI page-summariser. The command disabled AMSI (`AmsiUtils.AmsiInitFailed = true`), then downloaded and XOR-decoded (key 0x4A) shellcode from <https://cdn.cloud-endpoint.net/update>, injecting it via Add-Type [DllImport]. Corroborating network telemetry shows python.exe and powershell.exe connecting to cdn.cloud-endpoint.net (172.67.174.46) at 10:15–10:16.

Assessment: the summariser fetched an attacker-controlled page whose contents injected operating-system commands — an indirect prompt-injection / LLM-tool-abuse initial-access vector. *Source: WindowsProcess_CL (parent=python.exe), DeviceNetworkEvents; MDE alerts 'AdaptixC2 backdoor', 'AMSI tampering', 'process injected with malicious code' on GF-WS01.*

4.2 Execution, Defense Evasion & C2 — AdaptixC2

Defender identified the implant family as **AdaptixC2** (also flagged: PsAttack, Ceprolad). The actor disabled Defender features (T1562, 'Defender tamper: FeatureDisable' by GF-WS01\$) and tampered with AMSI. A beacon was observed via rundll32.exe to 57.155.101.212:443. Stage-2 tooling was staged to C:\Windows\Temp\svchost_upd.exe and C:\Windows\Temp\svc.ps1.

Source: MDE SecurityAlert/AlertInfo (GF-WS01), WindowsProcess_CL, DeviceNetworkEvents.

4.3 Persistence (GF-WS01) — three mechanisms

- **Scheduled task** 'MicrosoftHealthUpdate' — runs a hidden PowerShell IEX DownloadString loader as SYSTEM (/ru SYSTEM).
- **Registry Run key** HKLM\...\Run\WindowsHealthService' — same loader at logon.
- **Service hijack** — legitimate 'GFUpdaterSvc' stopped, its binary replaced with the payload at C:\ProgramData\GFUpdater\gfupdater.exe, then restarted.

Source: WindowsProcess_CL command lines; MDE alerts 'Scheduled task created ... by GF-WS01\sancadmin', 'Run key modified ... by GF-WS01\sancadmin'.

4.4 Credential Access & the svc_backup pivot

The actor targeted the backup service account directly (Get-ADUser svc_backup -Properties Description,ServicePrincipalNames), read cached credentials (cmdkey /list) and PowerShell history (ConsoleHost_history.txt), then reused svc_backup against 10.1.0.169 with three passwords in succession: **VeeamBackup2026!**, **BackupAdmin2025!**, **Greenfield2024**. Authentication telemetry shows failed svc_backup Type-3 attempts at 11:29 followed by a successful Type-3 logon to GF-SRV01 at 12:00:19 from 10.1.0.133 (GF-WS01).

Source: WindowsProcess_CL (net use commands); WindowsAuth_CL (Failure→Success, LogonType 3, SrcIpAddr 10.1.0.133 → GF-SRV01).

4.5 Lateral Movement — GF-SRV01

On GF-SRV01 (a Microsoft SQL / file server) the actor installed **AnyDesk** as a service for durable remote access, reset the domain password of **t.harris** to 'Summer2025' (net user t.harris Summer2025 /domain) to take over that identity, enumerated data services (FileZilla FTP, MSSQL) and ran recursive Robocopy staging of Finance data (12:53, 15:54, 18:54).

Source: MDE alerts (AnyDesk RAT, 'AdaptixC2 on a Microsoft SQL server', Robocopy staging, LDAP recon) on GF-SRV01; WindowsProcess_CL (net user ... /domain).

4.6 Domain Compromise — GF-DC01

The DC was reached two ways: t.harris (166 Type-3 logons from GF-SRV01 / 10.1.0.169) and svc_backup (successful Type-3 from the operator box 10.1.0.120 at 15:47). On the DC the actor ran Impacket remote-service execution (Defender: 'Ongoing hands-on-keyboard attack via Impacket toolkit', 'RemoteExec malware'), enumerated the directory (Get-ADUser/Group/Computer, repadmin) under the domain account **d.williams**, and dumped credentials — Defender 'Indication of local security authority secrets theft' (T1003.002 SAM, T1003.004 LSA Secrets). The actor then forged a **Kerberos Golden Ticket** (Defender 'Possible golden ticket attack', T1558.001), which requires and implies theft of the krbtgt key — i.e. total, persistent control of greenfield.local.

Source: MDE AlertInfo/AlertEvidence pinned to GF-DC01 (LSA secrets theft, Golden Ticket x2, Impacket x2, RemoteExec); WindowsAuth_CL; WindowsProcess_CL (repadmin by d.williams).

4.7 Collection & Exfiltration

Finance data was collected from \\GF-SRV01\Finance\Invoices (observed Copy-Item of invoice files), and domain/DC data was staged to C:\Windows\Temp\staged then archived with Compress-Archive to C:\Windows\Temp\exfil.zip (15:14). Exfiltration was performed via PowerShell HTTPS upload to the attacker-controlled Azure Blob **sanclogicart14191.blob.core.windows.net** (20.209.179.65) between 19:34 and 19:46. Defender also flagged 'Suspicious Network Beacons ... Exfiltration Over C2 Channel' (T1041) x30 on GF-WS01.

Source: WindowsProcess_CL (Compress-Archive, Copy-Item); DeviceNetworkEvents (powershell.exe → 20.209.179.65:443); MDE alerts (staging T1005/T1074/T1560, exfil T1041).

5. Compromised Credentials

Treat all of the following as compromised. Because krbtgt was compromised (Golden Ticket), **every account in greenfield.local must be considered exposed.**

Account	Type	How compromised / used
GREENFIELD\sancadmin	Domain admin-level	Primary hands-on account on GF-WS01; recon, persistence, tooling (also seen as GF-WS01\sancadmin).
GREENFIELD\svc_backup	Privileged service acct	Password reused/sprayed from WS01 to SRV01 (12:00) and to DC01 via operator box (15:47).
GREENFIELD\t.harris	Domain user	Password force-reset to 'Summer2025' on SRV01; used for RDP to SRV01 and 166 logons to DC01.
GREENFIELD\d.williams	Domain (admin-level)	Operated directly on the DC (repadmin/replication, AD enumeration).
krbtgt	Domain KDC key	Compromised via Golden Ticket forgery — enables forging tickets for ANY account indefinitely.
Local: VeeamBackup2026! / BackupAdmin2025! / Greenfield2024 / Summer2025	Passwords	Cleartext passwords observed in telemetry — must be retired everywhere.

6. Indicators of Compromise (IOCs)

Type	Indicator	Context
C2 domain	cdn.cloud-endpoint.net / api.cloud-endpoint.net	Stage-2 loader & C2 (Cloudflare-fronted)
C2 IP	172.67.174.46, 104.21.30.237	Resolutions for cloud-endpoint.net
C2 IP	57.155.101.212:443	AdaptixC2 beacon (rundll32.exe)
Exfil endpoint	sanclogcart14191.blob.core.windows.net (20.209.179.65)	Attacker Azure Blob — exfil.zip upload
Operator host	10.1.0.120	Attacker jump/operator box on subnet
File	C:\Windows\Temp\svchost_upd.exe	Stage-2 payload (certutil download)
File	C:\Windows\Temp\svc.ps1	Loader script (SYSTEM persistence)
File	C:\ProgramData\GFUpdater\gfupdater.exe	Hijacked service binary
File	C:\Windows\Temp\staged\ , C:\Windows\Temp\exfil.zip	Staging dir & exfil archive
Persistence	Scheduled task 'MicrosoftHealthUpdate'	SYSTEM logon persistence
Persistence	Run key 'WindowsHealthService'	HKLM...\CurrentVersion\Run
Persistence	Service 'GFUpdaterSvc' (hijacked)	Binary replaced with payload
Tooling	AdaptixC2, Impacket, AnyDesk, certutil, Robocopy	Implant / lateral / RAT / LOLBins
Malware	exfil via python.exe (page-summariser)	Initial-access vector

7. MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Initial Access	T1566 / T1059.001 (via LLM tool abuse)	python.exe → PowerShell on GF-WS01
Execution	T1059.001 PowerShell; T1204	AMSI-bypass loader; AdaptixC2
Defense Evasion	T1562.001 Impair Defenses; T1055 Process Injection	Defender/AMSI tamper; Add-Type shellcode
Persistence	T1053.005 Scheduled Task; T1547.001 Run Key; T1543.003 Service	MicrosoftHealthUpdate; WindowsHealthService; GFUpdaterSvc
Credential Access	T1003.002/.004 OS Cred Dumping; T1552	SAM/LSA/NTDS dump; cmdkey, PSReadLine
Discovery	T1087 / T1018 / T1069	net/AD enumeration; repadmin; port scans
Lateral Movement	T1021.002 SMB; T1021.001 RDP; T1550	svc_backup/t.harris; AnyDesk; Impacket
Persistence (Identity)	T1558.001 Golden Ticket; T1098 Account Manipulation	krbtgt forgery; t.harris password reset
Collection / Staging	T1005 / T1074 / T1560	Finance shares; staged\; Compress-Archive
Exfiltration	T1041 / T1567.002	Upload to attacker Azure Blob
Command & Control	T1071.001 / T1219	cloud-endpoint.net; AnyDesk RAT

8. Impact Assessment

- **Domain-wide compromise:** krbtgt / Golden Ticket means the attacker can authenticate as any user or service in greenfield.local, bypassing password resets, until krbtgt is rotated twice.
- **Data breach:** Finance/invoice data and domain data confirmed staged, archived and exfiltrated off-network to attacker cloud storage.
- **Durable access:** multiple persistence mechanisms (tasks, Run key, hijacked service, AnyDesk RAT) plus forged Kerberos tickets.
- **Blast radius beyond scope:** GF-BKP01 and GF-WEB01 were actively discovered and probed — potential further compromise.

9. Containment & Current Status

Microsoft Defender executed attack disruption on GF-WS01 (62 'Compromised device' alerts), limiting further activity from patient zero. However, containment on WS01 does NOT contain the domain: the Golden Ticket and stolen domain credentials remain usable from anywhere. GF-SRV01 and GF-DC01 were not auto-contained and must be assumed fully attacker-controlled.

10. Remediation — What to Fix

Immediate (now — contain the domain)

1. **Isolate GF-WS01, GF-SRV01 and GF-DC01** from the network; preserve for forensics before rebuild.
2. **Rotate the krbtgt password TWICE** (with the required interval) to invalidate the Golden Ticket. This is the single most important action.
3. **Disable / reset every account named here:** sancadmin, svc_backup, t.harris, d.williams — and force a domain-wide password reset, including all service accounts and local admins.
4. **Block IOCs at the perimeter:** cloud-endpoint.net, 172.67.174.46, 104.21.30.237, 57.155.101.212, and the exfil blob sanclogicart14191.blob.core.windows.net. Block/alert on 10.1.0.120.
5. **Hunt and remove persistence:** scheduled task 'MicrosoftHealthUpdate', Run key 'WindowsHealthService', hijacked service 'GFUpdaterSvc', and AnyDesk on SRV01.

Short-term (days)

1. **Rebuild GF-DC01 and GF-SRV01 from known-good media;** do not trust cleanup on a compromised DC. Plan AD recovery / forest-recovery guidance.
2. Investigate GF-BKP01 and GF-WEB01 for compromise; verify backup integrity and that backups are offline/immutable.
3. Quarantine the AI page-summariser: take it offline until it is re-architected; audit any host that runs it.
4. Review all Azure Blob / cloud egress logs to scope exactly what left the network and when.

Strategic (root-cause & hardening)

1. **Fix the initial-access vector:** the AI summariser must never execute or be able to influence execution of content it fetches. Sandbox it, drop its privileges, strip its ability to spawn shells, and treat fetched web content as untrusted data — not instructions.
2. **Privileged-account hygiene:** stop embedding passwords in account descriptions/scripts; make service accounts non-interactive, gMSA where possible, tiered admin model, and remove cached credentials.
3. **Harden identity:** LSASS protection (Credential Guard / RunAsPPL), SMB signing, restrict Type-3 logons for service accounts, and monitor DCSync/replication rights.
4. **Detection coverage:** alert on AMSI tampering, certutil downloads, LOLBin child processes of python.exe/office, Golden Ticket and Impacket patterns, and unapproved RMM tools (AnyDesk).
5. **Restrict outbound:** default-deny egress from servers/DCs; block unsanctioned cloud-storage and newly-registered domains.

Appendix — Methodology & Data Sources

Analysis was performed in Microsoft Sentinel / KQL across two workspaces. Primary process, authentication, network, DNS, registry and pipe telemetry (ASIM-normalised _CL tables) came from LAW-SilentCorridor; Defender XDR / MDE Device* tables, Identity events and Defender alerts came from LAW-Cyber-Range. All queries were scoped to the three in-scope hosts and the 4 Jul 10:00 – 5 Jul 03:00 UTC window. Shared cyber-range noise (student-authored analytics rules, Azure guest-agent activity, EDR/agent baseline) was identified and excluded; each finding was confirmed against underlying process/auth/network telemetry before inclusion.